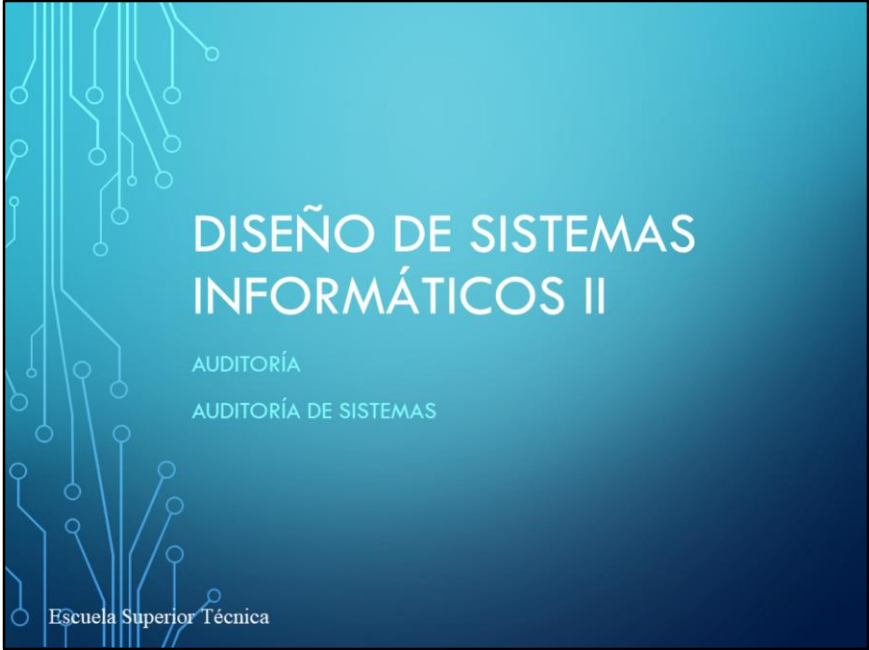




DISEÑO DE SISTEMAS INFORMÁTICOS II

AUDITORÍA

AUDITORÍA DE SISTEMAS

Escuela Superior Técnica

AUDITORÍA

- Es responsable de controlar a la empresa para salvaguardar los intereses de sus dueños.
- Puede ser un área interna o una organización externa.
- No tiene responsabilidades operativas de línea.
- No puede implementar acciones, sólo sugerirlas.

AUDITORÍA

- Según el aspecto de la Organización que controlen, hay varios tipos de auditorías:
 - De estados contables.
 - De procesos de negocio.
 - De sistemas informáticos.
 - De sistemas de calidad (ISO).

AUDITORÍA

- Auditoría de estados contables
 - Revisa el balance presentado por la Organización, y verifica:
 - Que represente razonablemente la realidad de la Organización.
 - Que cumpla los aspectos formales requeridos.
 - Si bien pueden existir auditorías internas, la firma y aprobación del balance, debe hacerla un auditor externo.

AUDITORÍA

- Auditoría de procesos de negocio:
 - Verifica las normas y procedimientos de la organización desde el punto de vista del control interno.
 - Verifica el cumplimiento de dichas normas e informa los casos de incumplimiento, evalúa su impacto y hace las recomendaciones del caso.
 - Verifica el cumplimiento de las normas legales vigentes.

AUDITORÍA

- Auditoría de Sistemas de Calidad:
 - Verifican si el área auditada cumple los requisitos específicos de calidad.
 - Generalmente, son externas y para obtener el certificado.
 - Un caso particular de auditoría de procesos del negocio.

AUDITORÍA

- Auditoría de Sistemas informáticos:
 - Dan soporte a los demás tipos de auditoría.
 - Evaluación de los riesgos y controles generales.
 - Evaluación de los riesgos y controles de la aplicación.

RIESGOS GENERALES

- La estructura del área de sistemas no garantiza un entorno de procedimiento controlable.
- El procedimiento de cambio de los programas no garantiza que se ejecuten los programas probados y autorizados por el área usuaria.
- Control de acceso: El acceso a los datos y programas no está resguardado de lectura, modificación y/o alteración no autorizada por terceros o personal de la empresa.
- Plan de contingencia: El Plan de continuación del negocio no garantiza el funcionamiento de las aplicaciones críticas ante contingencia y/o imprevistos.

ÁREA DE SISTEMAS

- Concentración de funciones incompatibles.
 - El desarrollo de Sistemas debe estar separado del área productiva de la organización (Usuarios).
 - Se puede controlar revisando los perfiles de usuarios.
- Usuarios sensitivos del Sistema:
 - Administrador de base de datos, Administrador de seguridad.
 - Necesitan acceso en ambos entornos. Deben ser monitoreados continuamente.

PROCEDIMIENTO DE CAMBIOS

- Todas las modificaciones al Sistema deben ser solicitadas, probadas y aprobadas por el área usuaria.
 - Solicitada formalmente por el área usuaria y debidamente autorizada.
 - Se debe garantizar que lo que el usuario probó es lo que se pasa al ambiente productivo.

PROCEDIMIENTO DE CAMBIOS

- Si el Usuario prueba en el ambiente de desarrollo, nada le asegure que lo que se pase a producción sea lo que él aprobó.
- Es necesario un ambiente intermedio de Aceptación, en donde no haya forma de modificar el sistema una vez aprobado.
- Quien pasa el fuente del ambiente de desarrollo al de aceptación no debe ser quien lo compila en aceptación.

PROCEDIMIENTO DE CAMBIOS

- El que hace el pasaje del ambiente de Aceptación a Producción es el responsable del mantenimiento de versiones operativas, quien pasa el ejecutable al ambiente de producción y cataloga la nueva versión fuente. (Bibliotecario).
- El bibliotecario será quien provea los fuentes para posteriores modificaciones.

PROCEDIMIENTO DE CAMBIOS

- Qué controlar:
 - Perfiles de usuario.
 - Lista del personal de sistemas.
 - Lista de aplicaciones críticas.
 - Revisar procedimientos de emergencia cuando el personal que realiza los cambios no está.
 - Historial de cambios realizados.
 - Quiénes pueden modificar los sistemas.

ACCESO GENERAL

- Es necesario poder asegurar que quienes acceden al sistema:
 - Sean quien dicen ser.
 - Tengan autorización para hacer lo que intentan hacer.
- Para lograr esto, deben identificarse en el sistema con un user-id y password.

ACCESO GENERAL

- Qué controlar:

- La password debe ser secreta y no fácilmente "adivinable".
 - Debe tener longitud mínima.
 - Combinar letras y números.
 - Tener periodo de expiración.
- Bloqueo ante intentos de acceso fallidos.
- Inhabilitación del usuario ante un periodo de inactividad prolongado.

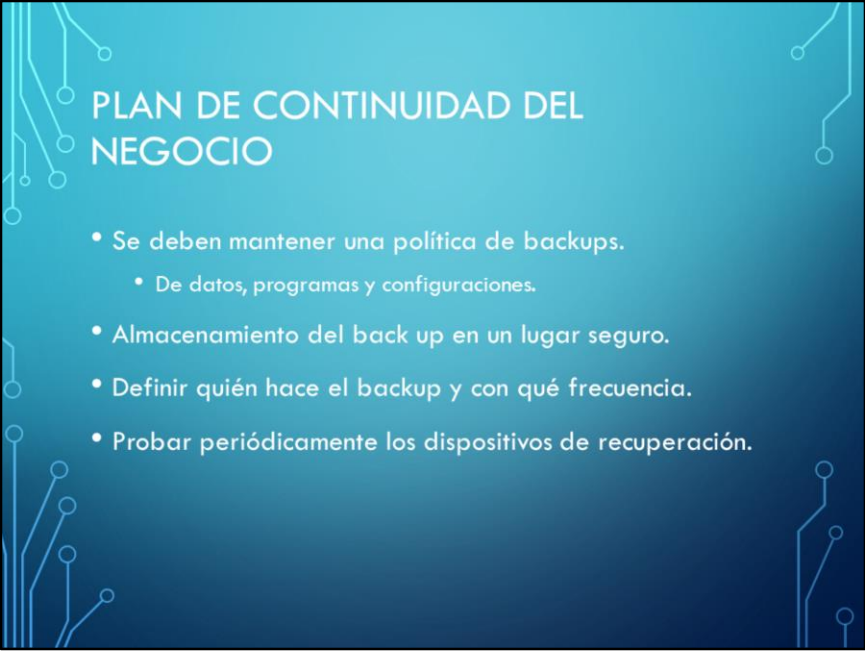
ACCESO GENERAL

- Restricción horaria de acceso
- Inhabilitación de la sesión ante un período de inactividad determinado.
- Compromiso de confidencialidad.
- Procedimiento ante olvido de password.
- Procedimiento ante finalización del contrato laboral.
- Procedimiento de alta de usuarios.
- Inhabilitar usuarios genéricos / públicos.
- Impedir sesiones simultáneas de un usuario.



PLAN DE CONTINUIDAD DEL NEGOCIO

- Hacer un inventario de todas las funciones críticas en la que centra su negocio.
 - Sistemas y aplicaciones que si no las tenemos operativas, no podemos seguir trabajando.
 - Posibles escenarios (internos y externos) que pongan en riesgo la continuidad del negocio.
- 



PLAN DE CONTINUIDAD DEL NEGOCIO

- Se deben mantener una política de backups.
 - De datos, programas y configuraciones.
- Almacenamiento del back up en un lugar seguro.
- Definir quién hace el backup y con qué frecuencia.
- Probar periódicamente los dispositivos de recuperación.

PLAN DE CONTINUIDAD DEL NEGOCIO

- Política de back ups. Un ejemplo:
 - De lunes a jueves, se realiza un back up diferencial: se copia todo lo modificado desde el último back up.
 - El viernes, se realiza un back up incremental: Se copia todo lo modificado desde el último back up y se lo marca como ya copiado.
 - El último viernes de cada mes, se realiza un back up total: Se copia todo y se lo marca como ya copiado

PLAN DE CONTINUIDAD DEL NEGOCIO

- Almacenamiento del Back up:
 - El back up diario lo guarda el Administrador del Sistema. (En la organización).
 - El back up semanal se lo lleva el gerente (a su casa).
 - El back up mensual se guarda en una caja de seguridad en el banco.

PLAN DE CONTINUIDAD DEL NEGOCIO

- En qué sitios alternativos se va a procesar mientras se reconstruyen las aplicaciones.
- Hay tres tipos de sitios alternativos:
 - Hot site: debe estar disponible las 24 horas.
 - Warm site
 - Cold site
- Ventana crítica: Es el tiempo del que se dispone desde la caída del sistema hasta poner en marcha el plan de contingencia.



PLAN DE CONTINUIDAD DEL NEGOCIO

- Tareas:
 - Quién debe lanzar el plan de continuidad del negocio.
 - Lista de personas a ubicar.
 - Inventario de hardware (perdido y necesario).
 - Lista de aplicaciones críticas a instalar.
 - Recuperación del back up.
 - Procedimientos de las aplicaciones no críticas.
- 

PLAN DE AUDITORÍA

- Objetivo: Qué queremos evaluar.
- Alcance: Desde / hasta.
- Metodología:
 - ¿Se revisará todo o una parte?
 - ¿Cómo se selecciona esa parte?
 - ¿Será sorpresiva la auditoría? ¿Se avisará antes?
 - ¿Quién la realizará? ¿Qué perfil tiene?

INFORME DE AUDITORÍA

- Para cada situación observada:
 - Situación detectada.
 - Riesgo y/o posibles consecuencias.
 - Recomendación
 - Razonable
 - Que agregue valor a la Organización
 - Opinión del área auditada.
 - Recomendación de nueva auditoría

INFORME DE AUDITORÍA

- Puede ser sintético o detallado según el destinatario.
- Debe incluir un diagnóstico ó conclusión general, donde indique si el ente auditado está bien, mal o hubo fraude a la auditoría.
- Incluir un curso de acción recomendado.